



Instituto Politécnico Nacional
Escuela Superior de Cómputo
Ingeniería en Sistemas Computacionales



“IT GOVERNANCE”

“Análisis de riesgos”

Hernández Aranda Hector Alejandro

Lagarza Ortega Ana Karen

Márquez Rodríguez Gael Alejandro

Trejo Hernández Brandon

7CV4

ROCIO PALACIOS SOLANO

MATRIZ CID

ACTIVO			VALORACIÓN CID						ANÁLISIS DE RIESGO			
ID Proceso	ID Activo	Activo de Información	C	I	D	Total	Valor 1	Valor 2	Vulnerabilidades	Amenazas	Evento de Amenaza (Riesgo)	Controles
OMNIS_USR_01	OMNIS_DAT_01	Datos personales de usuarios	5	5	3	13	Alto	3	Almacenamiento sin cifrado, acceso sin MFA, ausencia de enmascaramiento	Robo de credenciales, phishing, acceso no autorizado a BD	Fuga masiva de datos personales; violación LFPDPPP	Cifrado en reposo (AES-256), MFA, RBAC, logs de acceso
OMNIS_BD_02	OMNIS_BD_02	Base de datos de progreso	5	5	5	15	Alto	3	Sin respaldos automatizados, privilegios excesivos, BD expuesta sin firewall	Ransomware, fallo de hardware, eliminación accidental, SQLi	Pérdida permanente de progreso de alumnos y trazabilidad académica	Backups diarios RPO≤24h, firewall de BD, mínimo privilegio, cifrado
OMNIS_PAG_03	OMNIS_TRX_03	Transacciones y pagos	5	5	5	15	Alto	3	Sin tokenización PCI-DSS, TLS desactualizado, logs con datos de tarjeta	Intercepción de red, skimming digital, fraude en pasarela	Robo de datos financieros, fraude económico, pérdida de confianza	Tokenización, TLS 1.3, cumplimiento PCI-DSS, alertas de fraude
OMNIS_CRT_04	OMNIS_CRT_04	Certificados digitales	3	5	3	11	Alto	3	Firma sin validación criptográfica, sin CA confiable, claves débiles	Falsificación de certificados, clonación de credencial académica	Emisión de certificados fraudulentos, daño reputacional	Firma digital con CA confiable, hash SHA-256, validación en línea
OMNIS_MED_05	OMNIS_BLOB_05	Videos y recursos (Blob Storage)	1	3	5	9	Medio	2	URLs de blob públicas, sin CDN, sin redundancia geográfica	Caída del proveedor de nube, denegación de servicio, acceso no autorizado	Indisponibilidad de contenido educativo, latencia crítica en streaming	CDN multi-zona, Blob privado con SAS tokens, auto-scaling
OMNIS_WEB_06	OMNIS_WEB_06	Plataforma web y streaming	1	3	5	9	Medio	2	Sin WAF, dependencias desactualizadas, sin pruebas de carga	DDoS, XSS, caída por pico de tráfico	Indisponibilidad de la plataforma, interrupción de clases en vivo	WAF, SAST/DAST en CI/CD, auto-scaling, monitoreo de uptime
OMNIS_CAT_07	OMNIS_CAT_07	Catálogo de cursos	1	3	3	7	Medio	2	Sin control de versiones de contenido, edición sin autorización	Modificación no autorizada, inyección de contenido malicioso	Desinformación académica, daño a imagen institucional	Control de acceso por roles, versionado de contenido, auditoría

VALORACIÓN DE RIESGOS

ACTIVO				VALORACIÓN				TRATAMIENTO	
ID Riesgo	ID Activo	Amenaza / Vulnerabilidad	Activo Afectado	Probabilidad	Impacto	Nivel Riesgo	Riesgo Residual	Control / Tratamiento	Responsable
R01	OMNIS_BLOB_05	Caída o latencia del streaming	Reproductor · Blob · Nube	Media	Alto	Alto	Bajo	Auto-scaling, CDN y redundancia multi-zona	DevOps
R02	OMNIS_DAT_01	Brecha de datos personales	BD · Datos de usuarios	Media	Alto	Alto	Bajo	Cifrado en reposo/tránsito y control de acceso	Seguridad / Backend
R03	OMNIS_TRX_03	Fraude o interceptación en pagos	Pasarela · Transacciones	Media	Alto	Alto	Bajo	Tokenización, TLS y cumplimiento PCI-DSS	Backend / Finanzas
R04	OMNIS_WEB_06	Acceso no autorizado (cuentas/admin)	API · Plataforma	Media	Alto	Alto	Bajo	MFA, RBAC y tokens de sesión	Backend / Seguridad
R05	OMNIS_CRT_04	Falsificación de certificados	Certificados digitales	Baja	Alto	Medio	Bajo	Firma digital y validación criptográfica	Backend
R06	OMNIS_BD_02	Pérdida de datos por fallo de servidor	Base de datos	Baja	Alto	Medio	Bajo	Respaldos diarios (RPO ≤ 24 h) y restauración < 4 h	DevOps / DBA
R07	OMNIS_WEB_06	Ataque de denegación de servicio (DDoS)	Plataforma · Nube	Media	Medio	Medio	Bajo	WAF y mitigación en < 60 min	DevOps / Seguridad

R08	OMNIS_BLOB_05	Indisponibilidad del proveedor de nube	Infraestructura Azure	Baja	Alto	Medio	Bajo	Alta disponibilidad y despliegue multi-zona	DevOps
R09	OMNIS_WEB_06	Código vulnerable o dependencias inseguras	Backend · Frontend	Media	Medio	Medio	Bajo	Pruebas, cobertura ≥ 80 % y análisis SAST	Dev Team
R10	OMNIS_DAT_01	Error humano / fuga interna	Personas · Datos	Media	Medio	Medio	Bajo	Capacitación y principio de mínimo privilegio	RRHH / Seguridad

INFRAESTRUCTURAS CRITICAS

ACTIVO			VALORACIÓN						IDENTIFICACIÓN IC				
ID Proceso	ID Activo	Activo de Información	Área Geográfica	Período Afect.	Impacto	Cant. IC Afect.	Campos Afect.	Interdependencia	Criticidad	IC Detectada	Controles a Implementar	Grado	Responsable
OMNIS_BD_02	OMNIS_BD_02	Base de datos relacional	2	2	3	2	2	3	IV	Base de Datos (progreso, usuarios, pagos)	Cifrado AES-256, backups RPO≤24h RTO<4h, HA multi-zona, firewall BD	Crítica	DevOps / DBA
OMNIS_BD_02	OMNIS_WEB_06	Backend · API REST	2	1	2	2	2	3	IV	Backend de la plataforma educativa	Rate limiting, JWT, WAF, SAST, cobertura ≥80%, monitoreo	Crítica	Backend / Seguridad
OMNIS_PAG_03	OMNIS_TRX_03	Pasarela de pagos	2	1	3	1	2	2	IV	Procesamiento de transacciones de alumnos	Tokenización PCI-DSS, TLS 1.3, alertas de fraude, auditoría mensual	Crítica	Finanzas / Backend
OMNIS_MED_05	OMNIS_BLOB_05	Azure Blob Storage (videos)	2	2	3	2	2	3	IV	Almacenamiento y streaming de contenido educativo	CDN multi-zona, SAS tokens, replicación geo-redundante, auto-scaling	Crítica	DevOps
OMNIS_WEB_06	OMNIS_WEB_06	Plataforma web (frontend)	2	1	2	1	2	2	III	Interfaz de alumnos y docentes	WAF, CSP headers, DAST en pipeline, uptime monitoring	Alta	Dev Team
OMNIS_WEB_06	OMNIS_CI_07	Pipeline CI/CD	1	1	1	1	1	1	II	Automatización de builds y despliegues	Secrets cifrados, branch protection, PR obligatorio, dependabot	Media	DevOps